Maker Day 1

Cloud Security & Governance Challenges

Team #14

Date
Feb 13th, 2026

Organization
Google

The Problem - Onboarding to Google Cloud

Fragmented Onboarding Channels

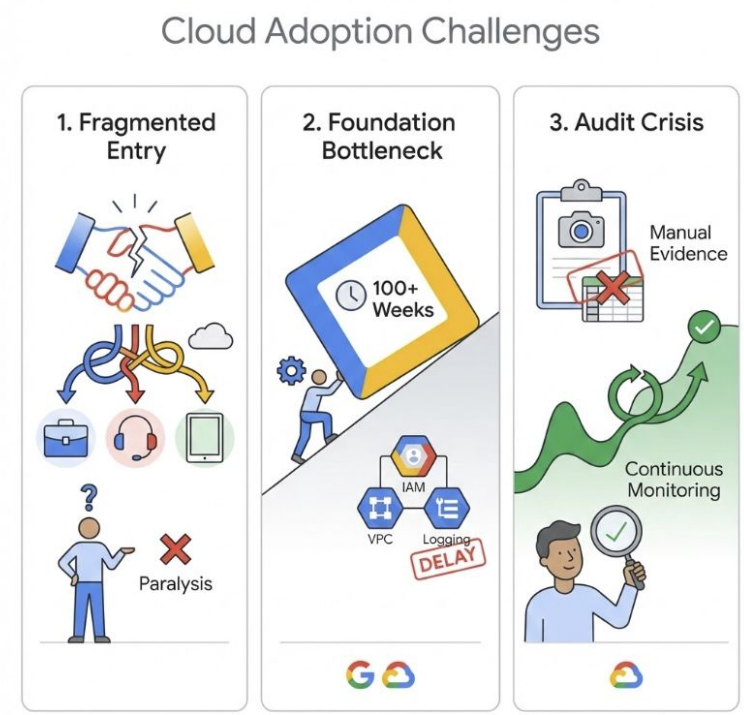
- Customers are funneled through confusing channels - Self-Service Consoles & Professional Service Blueprints

The "100-Week" Foundation Bottleneck

- 25 - 30 non-negotiable foundation services take 100+ weeks to be configured
- Regulated customers lack the specialized "Cloud-Native Risk" talent

The Audit Crisis: "Screenshots in Spreadsheets"

- Teams spend thousands of hours manually taking **console screenshots** and pasting them into static spreadsheets..
- Auditors are in need of **Continuous Control Monitoring (CCM)**, which the manual process cannot provide.



Deep diving into Audit Crisis

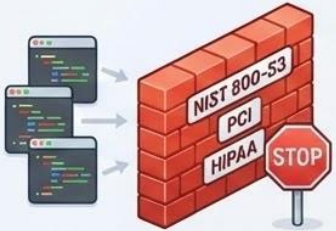
1. The Current State: “Manual Evidence Toil”

The Artifact Gap

Control owners (Security/Platform teams) manually navigate the console to capture screenshots as proof of implementation.

Disjointed Workflows

Evidence is pasted into spreadsheets/docs, separating the "proof" from the llve technical environment.



The Translation Wall

High friction in mapping raw configurations to regulatory catalogs (NIST 800-53, PCI, HIPAA).

Service Enablement Hurdle

Initial onboarding is stalled because every new service requires a fresh manual “Service Review.”

2. Core Bottlenecks

Point-in-Time Decay

Screenshots are stale upon capture. Any configuration drift immediately invalidates the manual "proof.”

The OSCAL Gap

Frameworks (OSCAL) provide guidance but lack the executable code (Rego/CEL) to verify the control automatically.

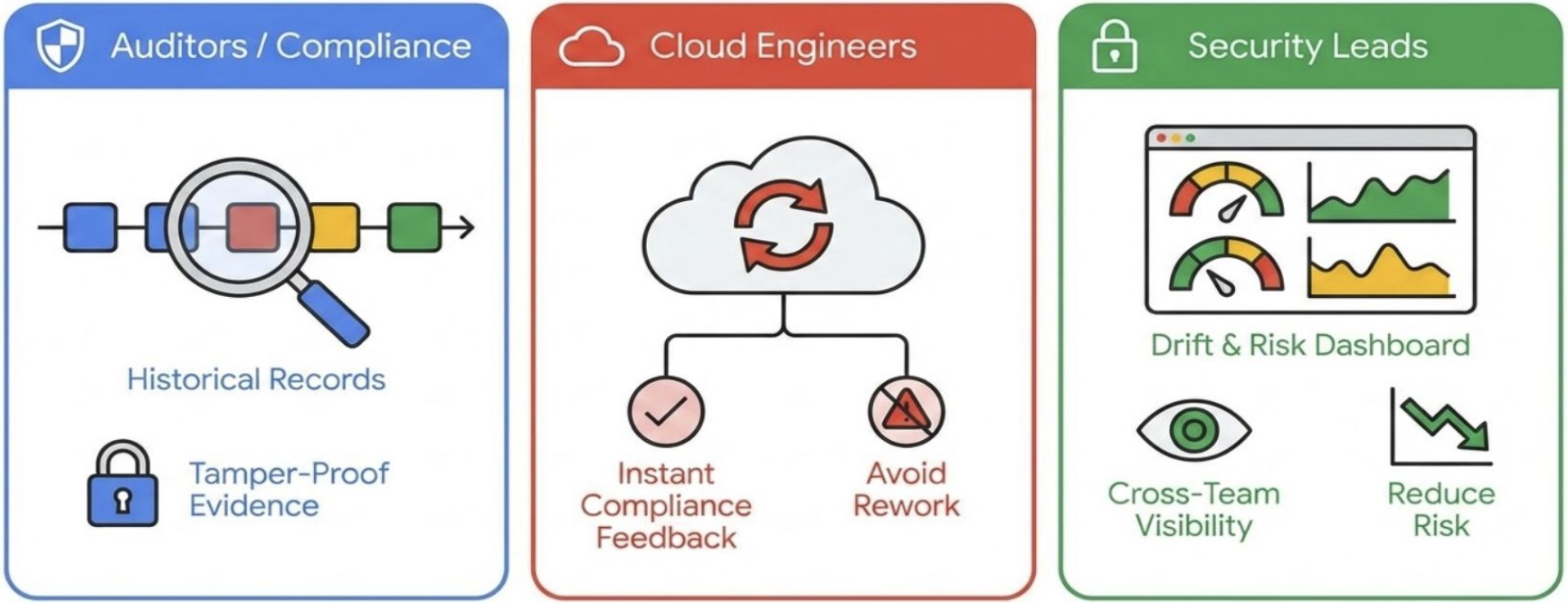
Feedback Latency

The "Rectification Loop" between control owners and compliance teams takes weeks per service, delaying Mean Time to Consumption.

Redundancy

Teams capture the same evidence multlple times for different frameworks due to a lack of Cross-Mapping automation.

User Profiles & User Needs



Market Research

Azure Purview

Multi-Cloud Support: ⚠️ Azure + M365 + limited AWS/GCP

Frameworks: 90+ (NIST, HIPAA, GDPR, ISO)

Continuous Monitoring: ✅ Yes

Preventive Controls: Via Azure Policy

Automated Remediation: ⚠️ Partial - guidance only

Security Posture: Requires Defender

Best For: Microsoft-centric orgs

AWS Audit Manager

Multi-Cloud Support: ⚠️ AWS only

Frameworks: 50+ (NIST, PCI, SOC, ISO)

Continuous Monitoring: ⚠️ Limited - scheduled runs

Preventive Controls: ❌ No enforcement

Automated Remediation: ❌ Guidance only

Security Posture: Via No Requires Polics

Best For: AWS audit teams

GCP Compliance Manager

Multi-Cloud Support: ⚠️ Google Cloud only

Frameworks: 40+ (NIST, CIS, PCI, HIPAA)

Continuous Monitoring: ✅ Yes

Preventive Controls: ❌ Cloud controls

Automated Remediation: ⚠️ Partial via controls

Security Posture: Via SCC integration

Best For: GCP compliance teams

Prisma Cloud

Multi-Cloud Support: ✅ AWS, Azure, GCP

Frameworks: 20+ plus custom

Continuous Monitoring: ✅ Real-time CSPM

Preventive Controls: ✅ Guardrail policies

Automated Remediation: ❌ SOAR integration

Security Posture: ✅ Built-in CSPM

Best For: Multi-cloud security

Current Google Customer Automation

Advanced Customers use Policy as Code:

Rego, Terraform Sentinel, CEL, etc.

```rego
package example.authz

# E123: Deny non admin users.
# Only admin users are allowed to access these resources.
deny contains {
    "code": 401,
    "message": "Unauthorized due to policy rule (E123)",
} if {
    input.admin == false
}
```

Options Available:

Open Source Projects

- Open Policy Agent (OPA)
- Continuous Compliance Framework (CCF)

Not all customers are tech savvy:

Using Rego or other open source projects require knowledge of programming

Opportunities

Custom Policy with Rego

Define precise, highly customizable policies for fine-grained control and flexibility across diverse cloud environments.

Automated Remediation

Implement self-healing infrastructure that automatically corrects policy violations, reducing manual effort and response times.

Framework Mapping & Agents

Map your cloud resources to compliance frameworks effortlessly and extend governance to any resource with lightweight agents.

Business Gains

Sell Policy Bundles

Create new revenue streams by offering customers custom policy packages and add-on governance products.

Tiered Security Offerings

Expand market reach by providing varied security tiers (basic, standard, premium) tailored to different customer segments.

Attract Compliant Customers

Lure enterprise clients with comprehensive compliance automation, significantly enhancing your market position and trustworthiness.

Sources - Aaron’s clarification on our specific questions

- Could you please walk us through the typical auditing workflow as it stands today?
- Regarding timelines - what’s a realistic window for a full audit in the current environment? We’ve heard of extreme outliers, but what does the general pattern look like across different types of enterprises?
- Is there a specific signal or data point Auditors are hunting for?
- Who is actually on the ground gathering these screenshots? Does that burden usually fall on the security, platform, or application teams?
- When we talk about the data being audited, which specific logs are we focusing on, and what’s the standard format? What software are stakeholders actually running on the console to generate this information?
- What do the day-to-day operations of continuous monitoring actually look like? Is it a constant stream of alerts, or more of a scheduled pulse check, and how much of an impact does that have on the team's workload?
- We’ve been thinking about converting policy checks into code via agents. How does that approach sit alongside something like Rego? If Rego is already 'Policy as Code,' where does an agent-based model add the most value?
- How does Security Command Center (SCC) currently fit into the compliance picture for frameworks like NIST? Is it a 'one-stop shop,' or are there still significant gaps that teams are having to bridge manually?
- Have you seen any customers successfully automate this, even partially? What was the 'tipping point' that allowed them to move away from manual checks?
- How does the audit cadence shift once a customer moves past the initial onboarding phase? Does it get easier, or does the drift make it more complex over time?
- What kind of specific guidelines or documentation are customers clinging to as their 'north star' during these audits?
- If we could actually solve for continuous control monitoring, what’s the real business win? Is it purely about saving hours, or does it fundamentally change the profit and risk profile of the onboarding process?

Thank You!

Unlocking New Opportunities

Custom Policy with Rego

Define and implement specific compliance rules for unique organizational needs using Rego, enhancing flexibility and control.

Automated Remediation

Implement automated actions to correct non-compliant configurations, significantly reducing manual effort and response times.

Framework Mapping & Agents

Leverage intelligent agents to automatically map controls to multiple compliance frameworks, ensuring comprehensive coverage without duplication.

These advanced capabilities empower teams to move beyond basic compliance, enabling proactive security, efficient operations, and robust governance across all cloud environments.

Opportunities & Impact Metrics

Opportunities

Custom Policy with Rego

Define preciee, custoimable policies for fine-grined control and flexibilty acrose cloud enviroiments.

Automated Remediation

Implement self-healing infrastrcture. ćorrect violations to slach manual effort effort and human error.

Framework Mapping & Agents

Effortttelly map resources to compliance framerrk goverance to any resource via lightweight agents

Business Gains

New Revenue: Policy Bundles

Offer custom paccurity leader ?ego aas through complehs arvak maprgin add-od governance products

Leader in Cloud Security

Position setup time tine a security leader through pletnive framework mapping and advanced agents

Market Expansion

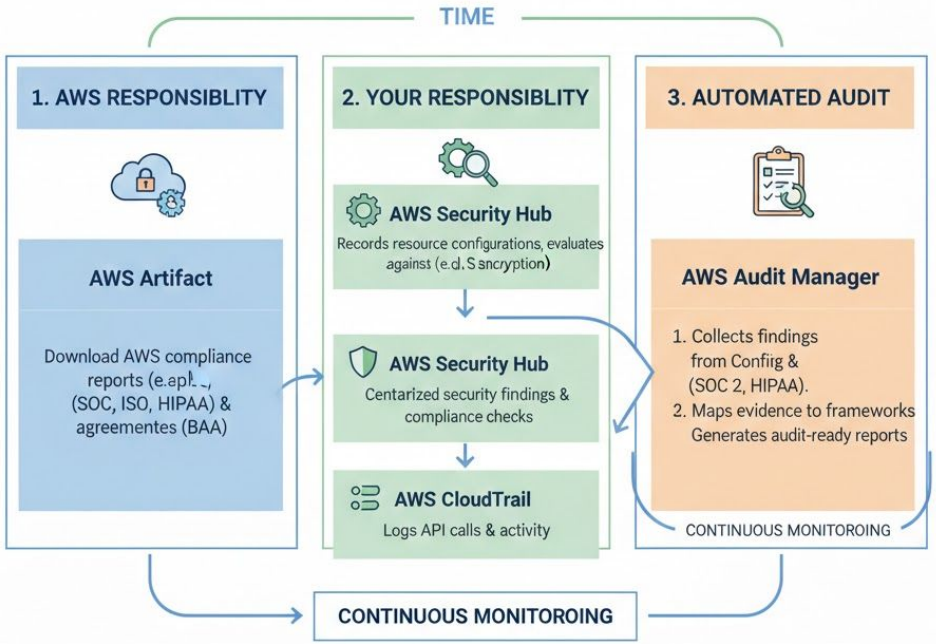
Attract more compliant thrarvecurity customrring pre-valleated and endices tirres tiered offerings

Key Takeaway

By shifting from manual ovesright to automated, Rego-based governance, we aren't just security– we creating a scalable a scalable product ecosystem that reduces obabrding friction friction and creates recurring revenue.

AWS COMPLIANCE TOOLSET: HOW IT WORKS TOGETHER

A Unified Workflow for Security & Regulatory Requirements



Key: Light Blue = AWS's Proof
Light Green Your Monitoring